Gmail **Kamron Saparbaev <[redacted]>**

RE: [EXT]

6 messages

ATTACK <attack@mitre.org> Wed, Nov 5, 2025 at 9:51 PM
To: Kamron Saparbayev <[redacted]>

Thank you for following up. We have added this to our research queue. We will let you know if there are any follow up questions or updates from us.

Thanks!

Lauren Lusty

-----Original Message-----

Priority: Normal

From: (Kamron Saparbayev) [redacted]

Sent: 11/5/2025

To: (ATTACK) attack@mitre.org

Cc:

Subject: [EXT] [redacted]

Hi MITRE ATT&CK Team,

Yes, there is real-world evidence of attackers using the same techniques.
For example, in a 2025 report by HP Wolf Security, researchers monitored attackers hiding malware in images using steganography to bypass defenses. The malicious code was then executed after extraction, leading to the installation of info-stealers like VIP Keylogger and 0bj3ctivityStealer.

Reference:
https://prevent-ransomware.com/blog/hackers-hide-malware-in-images-why-detection-alone-wont-save-you

I maintain a research PoC (ShadowImageExec) that demonstrates an automated agent decrypting AES payloads embedded in media files and executing them;

Link to download (Google Drive):
[redacted]

Filename: ShadowImageExec-sanitized.zip
SHA256 checksum: 7f6699577e1da5f889f8770884e061cb223082b949e2310b7c4ebba7fa5ed135

For safety and ethical reasons, the package has been sanitized and contains no runnable binaries or destructive commands. The archive is password-protected; I will share the password
ShadowImageExec-sanitized.zip's password: [redacted]

I am also fine with being listed as a contributor under my full name: **Kamron Saparbayev**.

Best regards,
Kamron Saparbayev

Kamron Saparbayev <[redacted]> Wed, Nov 5, 2025 at 10:35 PM
To: ATTACK <attack@mitre.org>

Thank you for your response.

ср, 5 нояб. 2025 г. в 13:51, ATTACK <attack@mitre.org>:
[Quoted text hidden]

ATTACK <attack@mitre.org> Wed, Nov 12, 2025 at 7:42 PM
To: Kamron Saparbayev <[redacted]>

Hi,

Wanted to follow up to see why you think this behavior doesn't fall under the current technique for Steganography. https://attack.mitre.org/techniques/T1001/002/

Thanks,

Lauren Lusty

-----Original Message-----

Priority: Normal

From: (Kamron Saparbayev) [redacted]

Sent: 11/5/2025

To: (ATTACK) attack@mitre.org

Cc:

Subject: Re: [EXT]

[Quoted text hidden]

Kamron Saparbayev <[redacted]> Wed, Nov 12, 2025 at 8:23 PM
To: ATTACK <attack@mitre.org>

Hi Lauren

Thanks for the question and for adding this to the research queue. Below is a brief explanation of why we believe the observed behavior does not fully map to the T1001.002 — Steganography technique:
Difference in purpose: T1001.002 describes the main idea of steganography as a means to hide C2 traffic. In our research, steganography serves to deliver the AES-encrypted payload in a covert manner, which then automatically gets executed. Here, the main intent is not about hidden communication but rather about covert delivery and execution.

Difference in the model of execution. In the classic T1001.002, the C2 server receives/interprets the data that is hidden. In our PoC, an agent extracts the encrypted content from a file, decrypts it with AES, and immediately executes it. That's a "download → decrypt → execute" flow, which is closer to Ingress Tool Transfer or Execution rather than pure C2 steganography.

Combined technique. In our case, Steganography is merely a transport mechanism; the main event is the delivery and execution of malicious code. Given that, it would be more appropriate to model this as a combination (Steganography + Ingress Tool Transfer/Execution) or to define a new sub-technique describing “covert delivery of encrypted artifacts that are automatically executed.”

Defensive implications. If this scenario is classified only under T1001.002, defenders may focus mainly on detection of C2 channels. Our scenario adds more indicators such as modifications of media files, calls to encryption/decryption utilities, and automated execution events. It will be detectable with broader telemetry and analytic coverage.

Also, the sample you already got - ShadowImageExec-sanitized.zip (SHA256: 7f6699.d135) - technically shows this behavior.

Please feel free to get in touch with me for any further questions or updates you might have.

Best regards,

Kamron Saparbayev

ср, 12 нояб. 2025 г. в 11:42, ATTACK <attack@mitre.org>:
[Quoted text hidden]

Kamron Saparbayev <[redacted]> Thu, Dec 18, 2025 at 8:56 PM
To: ATTACK <attack@mitre.org>

Hi Lauren
I hope you are doing well. I wanted to kindly follow up regarding the status of my submission, as some time has passed since I shared the report.
Please let me know if any additional information or clarification is needed. I would be happy to assist.
Thank you for your time and consideration.
Best regards,
Kamron Saparbayev
[Quoted text hidden]

Kamron Saparbayev <[redacted]> Wed, Jan 14, 2026 at 9:57 PM
To: ATTACK <attack@mitre.org>

Hi Lauren

Thanks for the question and for adding this to the research queue. Below is a brief explanation of why I believe the observed behavior does not fully map to the T1001.002

— Steganography technique:
Difference in purpose: T1001.002 describes the main idea of steganography as a means to hide C2 traffic. In our research, steganography serves to deliver the AES-encrypted payload in a covert manner, which then automatically gets executed. Here, the main intent is not about hidden communication but rather about covert delivery and execution.

Difference in the model of execution. In the classic T1001.002, the C2 server receives/interprets the data that is hidden. In our PoC, an agent extracts the encrypted content from a file, decrypts it with AES, and immediately executes it. That's a "download → decrypt → execute" flow, which is closer to Ingress Tool Transfer or Execution rather than pure C2 steganography.

Combined technique. In our case, Steganography is merely a transport mechanism; the main event is the delivery and execution of malicious code. Given that, it would be more appropriate to model this as a combination (Steganography + Ingress Tool Transfer/Execution) or to define a new sub-technique describing “covert delivery of encrypted artifacts that are automatically executed.”

Defensive implications. If this scenario is classified only under T1001.002, defenders may focus mainly on detection of C2 channels. Our scenario adds more indicators such as modifications of media files, calls to encryption/decryption utilities, and automated execution events. It will be detectable with broader telemetry and analytic coverage.

Also, the sample you already got - ShadowImageExec-sanitized.zip (SHA256: 7f6699.d135) - technically shows this behavior.

Please feel free to get in touch with me for any further questions or updates you might have.

Best regards,

Kamron Saparbayev

[redacted]

[Quoted text hidden]